
Tutorial 7

Network Defense: Firewalls and Tunnels

Computer Security

BCS2420

Part A

1. A company has a strict firewall configuration that drops all incoming connections except on port 80 (HTTP). Which statement about this policy is correct?
 - ☐ It completely prevents attackers from sending malicious content over HTTP.
 - ☐ It enforces a default-deny stance, reducing the attack surface except for allowed ports.
 - ☐ It is useless if the network has internal malicious insiders.
 - ☐ It automatically protects against tunneling protocols.
2. Which scenario **best** demonstrates the advantage of using *stateful* firewalls over *stateless* ones?
 - ☐ Dropping malformed packets based solely on IP header checks.
 - ☐ Allowing inbound HTTP responses only if they correspond to an *established* outbound HTTP session.
 - ☐ Logging all ICMP packets from external networks.
 - ☐ Rejecting all incoming traffic from private IP addresses.
3. A DMZ segment in a firewall architecture is primarily used to:
 - ☐ Provide a *trusted* internal subnet that only employees can access.
 - ☐ Host *public-facing services* (e.g., web servers) with restricted connectivity to the internal network.

- ☐ Encrypt all traffic crossing the perimeter.
 - ☐ Replace the need for a dedicated bastion host.
4. Which of the following is **not** a typical limitation or weakness of traditional firewalls?
- ☐ They assume a clearly defined network perimeter that might not exist in modern environments.
 - ☐ They cannot inspect or block encrypted content (unless configured with special mechanisms).
 - ☐ They automatically detect malicious insiders and block their traffic.
 - ☐ They can be bypassed by protocols tunneled over allowed ports.
5. Which statement about **proxy firewalls** is **true**?
- ☐ They only operate at the network layer (layer 3) and cannot inspect application data.
 - ☐ They relay traffic at the application or circuit level, potentially examining content for malicious patterns.
 - ☐ They are always slower than packet filters because they drop all packets.
 - ☐ They do not require any specialized software—just normal router firmware.
6. How does **SSH port forwarding** (local forwarding) increase security for an application protocol that normally sends data in the clear?
- ☐ It compresses the data to reduce bandwidth.
 - ☐ It encapsulates the application's plaintext traffic within an encrypted SSH session, preventing eavesdropping.
 - ☐ It blocks all inbound connections to the server.
 - ☐ It automatically replaces user authentication with a certificate.
7. A firewall with a *default-allow* policy means:
- ☐ All traffic is blocked unless specifically permitted by a rule.
 - ☐ All traffic is allowed unless specifically denied by a rule.
 - ☐ The firewall denies all traffic to or from port 80 and 443.
 - ☐ The firewall logs inbound traffic but does not enforce rules.

8. What is the key characteristic of *tunnel mode* VPN in IPsec?
- ☐ It encrypts only the TCP header, leaving IP addresses unencrypted.
 - ☐ It encapsulates the entire IP packet (including headers) within a new IP header, providing site-to-site encryption.
 - ☐ It never authenticates packet sources, only encryption.
 - ☐ It is used solely for host-to-host encryption, not site-to-site.
9. Why is *port knocking* sometimes used in conjunction with firewalls?
- ☐ To open inbound ports only after a secret sequence of connection attempts (knocks) is made, enhancing stealth and reducing exposed services.
 - ☐ To forcibly close all ephemeral ports once a user logs out.
 - ☐ To automatically switch the firewall from default-deny to default-allow.
 - ☐ To enable dynamic NAT for inbound connections.
10. Traditional FTP uses separate control and data channels. A **stateful** firewall that supports FTP typically:
- ☐ Rejects all inbound data connections since they are never recognized.
 - ☐ Dynamically opens the required data port upon seeing the PORT/PASV command on the control channel.
 - ☐ Depends on default-allow policy for inbound ports.
 - ☐ Cannot handle passive FTP at all.
-

Part B

1. **Choke-Point Security**

- **Question:** In a modern enterprise with distributed, cloud-based services, how does the *traditional* concept of a network choke point (single firewall perimeter) become less effective? Propose **two** ways organizations adapt firewall usage to handle this shift.

2. **Default-Deny vs. Default-Allow**

- **Question:** Compare the **default-deny** and **default-allow** approaches in firewall rulesets. Discuss **one** advantage and **one** disadvantage of each approach, and clarify which is typically more secure by default.
- 3. **Stateful vs. Stateless Firewall**
 - **Question:** Outline the *functional* difference between a *stateless* packet filter and a *stateful* inspection firewall. Give a real-world example (beyond the standard TCP handshake check) where stateful behavior clearly outperforms stateless filtering.
- 4. **VPN Modes**
 - **Question:** Explain the difference between *transport mode* and *tunnel mode* in IPsec-based VPNs. In which scenario might *transport mode* be preferable, and why?
- 5. **SSH Security**
 - **Question:** Traditional telnet is insecure because data flows in plaintext. Demonstrate how **SSH** addresses confidentiality and integrity for remote shell connections. Also, describe how server authentication works in SSH to prevent MITM.
- 6. **Proxy-based Firewalls**
 - **Question:** Compare *circuit-level* and *application-level* proxy firewalls. Which type can filter at the level of HTTP or FTP commands, and which is more limited in protocol understanding? Also mention how proxies can hamper performance.
- 7. **DMZ Architecture**
 - **Question:** Illustrate a **DMZ** architecture with at least **two** screening routers and a bastion host. Show how external users reach the DMZ but have limited access to the internal network. Why is this design favored for public-facing servers?
- 8. **Firewall Limitations**
 - **Question:** Summarize **two** fundamental firewall limitations that cannot be solved by more advanced filtering rules. For each limitation, suggest a complementary security measure to mitigate it.
- 9. **SSH Port Forwarding**
 - **Question:** Provide a scenario where local **SSH port forwarding** solves a security or connectivity problem. Describe how data from an insecure protocol is

encapsulated and how the user sets up such a tunnel.

10. **Layered Defense**

- **Question:** Why do organizations often deploy multiple firewall layers (e.g., perimeter firewall + host-based firewall)? Discuss how a host-based firewall on a server can complement the perimeter firewall's policy, including an example of an insider threat scenario.
-